

The Art of Guard

Part 1

Your first steps with SELinux.

From the 6th century BC, around the time the *Art of War* was written by Sun Tzu, till today, the basic tenets of warfare (attack/offence) and security (defence) remain the same. What has changed significantly from those days is the terrain. It has evolved from land and sea, to air and into cyberspace.

Securing cyberspace, especially in this connected world of the Internet, is of prime concern to governments, organisations and individuals. In a knowledge economy, the real wealth is in information and the bits of data that provide it.

Securing access to that data is of fundamental importance to the very existence of an organisation. CIOs and IT managers worldwide therefore look at security as one of their main areas of concern. IT security is a vast subject and covers many areas—the foremost being network security (firewalls), data security (encryption, backup, etc), computing security (restricting physical access, patching OS vulnerabilities, etc) and application security. Much attention has been paid to network security, data security and computing security, and thus there are a lot of products in the market competing with each other providing security solutions in these spaces.

But simply buying and implementing the security products is not enough. As Bruce Schneier states in his remarkable book, *Secrets and Lies: Digital Security in a Networked World*, the two fundamental principles about digital security are:

- Security is a chain; it's only as secure as the weakest link.
- Security is a process, not a product.

The application is a very important link in the IT security chain. It is the application that the end-user consumes and it is the application interface that is exposed to all users (even those without proper login credentials). These applications control the use of resources granted to them by the OS—memory, storage, networks, etc. Most applications are complex and run into tens of thousands of lines of code and can contain innumerable vulnerabilities.

Moreover, typically, multiple applications are executed on the same operating system instance. To give a simple example, a mail server running SMTP/POP/IMAP will, in



all probability, also be running a Web server. The Web server interface could be used for configuration or even for Web mail purposes.

Vulnerabilities in one application could bring down the entire system affecting other services and processes, or worse, lead an attacker to a storehouse of confidential information.

Why SELinux?

Application software will have its flaws and bugs, and will remain like that in the near future, depending on the nature

of the application and the constraints/awareness of the developers.

If multiple applications running on the same OS have to be secured, the OS has to play a crucial role in defining the confines of these applications. Security can only be achieved with better underlying operating system security that can isolate applications and files used by each, thus protecting the integrity of the entire system.

In most organisations that have implemented some form of security and have a security policy in place, the weakest link in the security chain are the systems administrators. They generally have access to most files in the system and can—by accident or design—perform operations on confidential files. Confidentiality of data in modern systems is another pressing requirement.

The NSA (National Security Agency) of the US, which originally developed SELinux, states: "The Security-enhanced Linux's new features are designed to enforce the separation of information, based on confidentiality and integrity requirements. They are designed for preventing processes from reading data and programs, tampering with data and programs, bypassing application security mechanisms, executing untrustworthy programs, or interfering with other processes in violation of the systems security policy. They also help to confine the potential damage that can be caused by malicious or flawed programs. They should also be useful for enabling a single system to be used by users with differing security authorisations to access multiple kinds of information with differing security requirements without compromising those security requirements."

In other words, SELinux does implement some kind of Access Control Mechanism to achieve the above.